

**SIMATS ENGINEERING (SAVEETHA SCHOOL OF
ENGINEERING)** Department of Computer Science and Engineering

ASSESSMENT TOOL 2 – INCIDENT ANALYSIS (ROOT CAUSE & RISK)

Course Code:	CSA5802	Course Title:	DEVSECOPS ENGINEERING AND APPLICATION SECURITY
CO Assessed:	CO5 – Precision (BL1, BL2, BL3)	Assessment:	Assessment Tool 2
Weightage:	30% of CIA	Total Marks:	100
CO5 Statement:	Incident Investigation, Root Cause Analysis and Risk Assessment.		
Student Name:	K.Yalla Reddy	Reg. No.:	192465047
Section / Batch:	2024	Date:	27-08-2026

Instructions to Students

- Review the given security incident scenario, evidence, logs and indicators carefully before beginning the analysis.
- Identify the incident sequence, affected assets, relevant indicators and supporting evidence without making unsupported assumptions.
- Determine the root cause by linking observed events, vulnerabilities and contributing conditions in a logical sequence.
- Assess identified risks based on likelihood, severity and potential technical or operational impact. • Present investigation findings, root-cause reasoning and risk assessment clearly with appropriate technical justification.

INCIDENT ANALYSIS Investigation & Risk Q1

Q1 – 100

1. Executive Summary

This documentation analyzes a suspected internal reconnaissance incident in which a student endpoint is observed scanning multiple campus VLANs. The central security concern is not merely the volume of traffic, but the cross segment behavior: a device associated with a student/BYOD context is attempting connections to systems outside its expected trust boundary. Such behavior can indicate unauthorized discovery, malware activity, credential compromise, or an improperly authorized security-testing tool. The analysis therefore avoids treating the scan itself as proof of compromise and instead uses correlation of NAC, DHCP, switch, IDS/IPS, firewall and endpoint evidence to determine intent and impact.

The recommended response is defense-in-depth: validate the device identity and activity; contain it using NAC-driven VLAN isolation; use IDS/IPS to detect and, where appropriate, block malicious scanning and exploit traffic; then remediate the endpoint before restoring normal access. Segmentation limits lateral movement, while endpoint remediation removes the underlying cause if the device is compromised.

2. Incident Scenario and Objectives

Scenario: A campus-network dashboard reports repeated connection attempts from a student device at 10.20.15.47 toward multiple internal VLANs. The device is associated with a BYOD/student access segment. The dashboard indicates repeated probes involving services such as TCP/22, TCP/80, TCP/443 and TCP/445. The security team must determine whether this is authorized activity or suspicious reconnaissance, contain the risk, and restore the device only after security posture has been verified.

Incident-analysis objectives:

- Identify the incident sequence and relevant indicators of compromise or suspicious behavior.
- Identify affected assets and trust boundaries without making unsupported assumptions.
- Determine the most probable root cause and contributing conditions.
- Assess likelihood, severity and operational/technical impact.
- Recommend NAC VLAN isolation, IDS/IPS controls and endpoint remediation.
- Define evidence preservation, recovery and lessons-learned activities.

3. Dashboard Evidence and Initial Observations

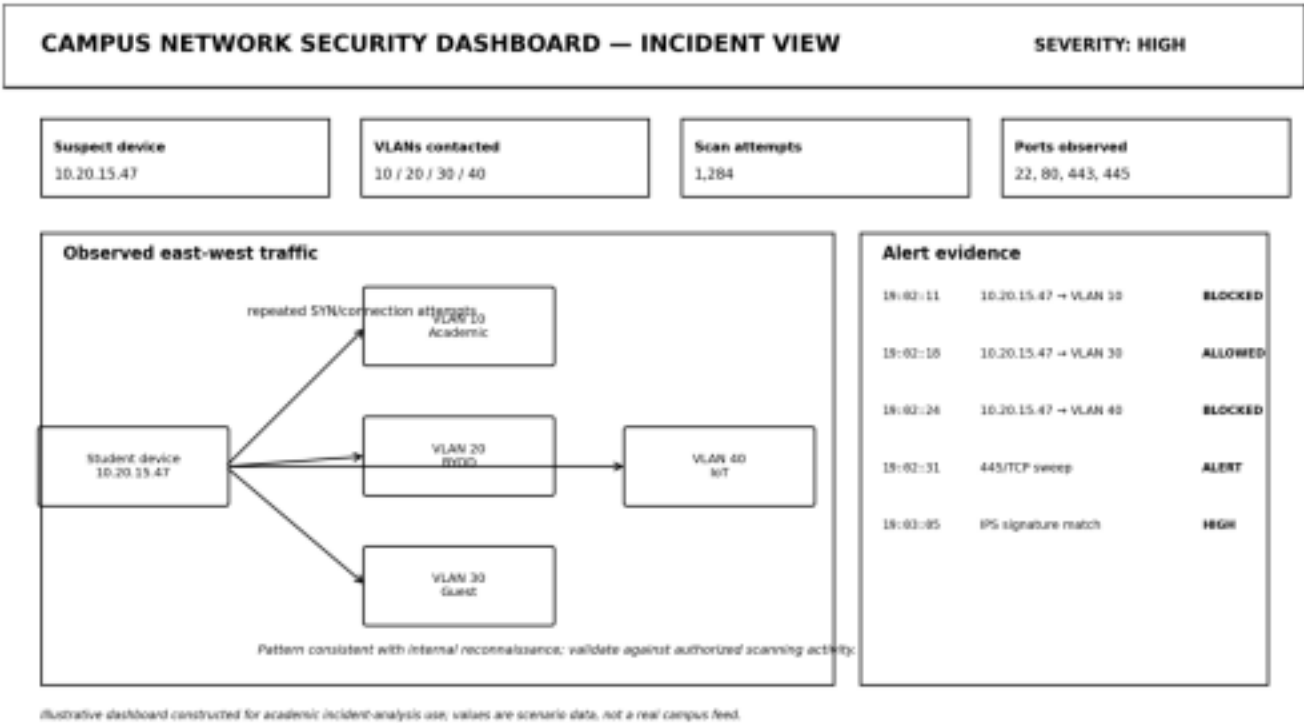


Figure 1. Illustrative campus security dashboard showing a student endpoint probing multiple internal VLANs.

The dashboard is an academic illustration of the evidence pattern described in the question. The strongest initial indicator is cross-VLAN scanning from a device that should have limited peer reachability. A single scan does not establish malicious intent; the investigation must establish whether the activity was authorized, automated by legitimate software,

or associated with compromise.

4. Incident Indicators

Indicator	Observed/Expected Evidence	Security Meaning	Priority
Source endpoint	10.20.15.47 / student BYOD context	Anchor for identity and device ownership	High
Cross-VLAN attempts	Targets VLAN 10, 30 and 40	Possible boundary probing/lateral discovery	High
Repeated SYN/connection attempts	1,284 scan attempts in scenario dashboard	Reconnaissance-like behavior	High
SMB/445 activity	TCP/445 probe observed	Potential Windows-service discovery or exploitation path	High
IPS alert	Signature match on scan pattern	Independent network security corroboration	High
NAC posture	Must verify identity, compliance and role	Determines whether device should remain on BYOD VLAN	High

5. Incident Sequence / Attack-Path Reconstruction

Stage	Analysis
T0 – Normal access	Student device authenticates to the campus network and receives a BYOD/student network identity.
T1 – Reconnaissance begins	The endpoint generates repeated connection attempts to hosts/services outside its normal communication pattern.
T2 – Cross-VLAN probing	Traffic reaches or attempts to reach multiple VLANs, indicating that inter-segment controls should be examined.

T3 – Detection	Dashboard analytics and/or IDS/IPS generate alerts; switch, DHCP and NAC logs provide attribution evidence.
T4 – Validation	SOC correlates MAC address, IP lease, username/device identity, access point/switch port and endpoint telemetry.

T5 – Containment	NAC changes the endpoint's authorization state and places it in a restricted Quarantine VLAN or equivalent policy group.
T6 – Remediation	Security staff inspect the endpoint, remove unauthorized tools/malware, patch software, verify configuration and rescan.
T7 – Recovery	Only after clean posture and authorization are confirmed is normal access restored; monitoring remains elevated.

6. Affected Assets and Trust Boundaries

Potentially affected assets include the student endpoint itself, internal hosts in the probed VLANs, access switches and wireless infrastructure, identity/NAC services, and security monitoring systems. The highest concern is lateral movement: if the source endpoint is compromised, unrestricted east-west access could allow discovery of vulnerable systems and increase the blast radius.

Asset/Zone	Purpose	Risk if Reached Recommended Boundary
Student/BYOD VLAN	Personal student endpoints	Compromised Restricted client-to-client peer-to-peer activity access
Academic/Managed VLAN	University-managed endpoints	Credential/data exposure Allow only required and lateral movement services
Guest VLAN	Visitor access	Cross-tenant exposure Internet-only where feasible
IoT VLAN	Cameras, sensors and devices	Weakly protected device Strict allow-listing compromise

Management VLAN	Network/security administration	High-impact infrastructure	Admin-only, tightly controlled
Quarantine VLAN	Containment/remediation	compromise	Limited operational risk Only remediation services permitted

7. Root Cause Analysis

The most defensible root-cause statement at the initial investigation stage is: "An endpoint operating under a student/BYOD access identity generated unauthorized or anomalous cross-VLAN reconnaissance traffic, and the existing network controls either permitted the traffic or did not isolate the endpoint quickly enough." The underlying reason for the scan cannot be concluded from the dashboard alone.

7.1 Five-Why Analysis

Question	Answer
Why was the security alert generated?	The endpoint made repeated connection attempts to multiple internal VLANs.
Why could it attempt multiple VLANs?	Inter-VLAN routing and/or security policy permitted at least some traffic, or controls were not sufficiently restrictive.
Why was the behavior suspicious?	The endpoint's role did not require broad internal discovery, and the pattern resembled reconnaissance.
Why could the activity persist?	Detection, NAC enforcement and endpoint response were not yet correlated into an automatic containment workflow.
Root cause / contributing condition	Insufficient least-privilege segmentation and/or delayed posture-based isolation allowed a student endpoint to perform cross-segment reconnaissance.

Alternative causes to test before declaring compromise include: authorized penetration testing, a vulnerability scanner, administrator troubleshooting, a misconfigured application, automated software discovery, or malware. The investigation should use change records, security-team approvals, process ownership and endpoint telemetry to distinguish these cases.

8. Mitigation Strategy

RECOMMENDED CAMPUS SEGMENTATION AND CONTROL POINTS

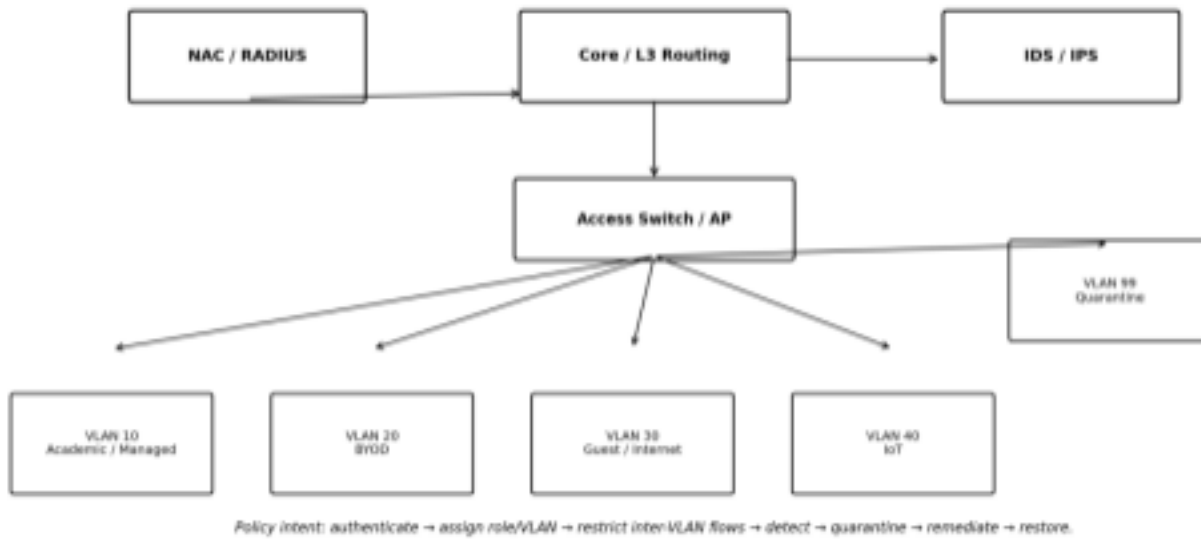


Figure 2. Recommended segmentation and control points for a secure campus response.

8.1 NAC VLAN Isolation – Primary Containment

Network Access Control should evaluate identity, device posture and authorization context before granting normal access. For the suspicious endpoint, NAC should dynamically assign a Quarantine/Remediation VLAN (or an equivalent restricted policy group). The quarantine segment should permit only the services required for remediation, such as DHCP, DNS, update repositories, endpoint-management servers and security tooling. It should deny unnecessary access to academic, management, server and IoT networks.

Justification: VLAN isolation reduces the endpoint's reachable attack surface and prevents a potentially compromised student device from freely moving laterally while investigation continues. Segmentation is most effective when inter VLAN traffic is also enforced by ACLs, firewall policy or equivalent controls; placing a device in a VLAN alone should not be treated as sufficient isolation.

8.2 IDS/IPS – Detection and Active Prevention

IDS should provide visibility into east-west scanning, unusual connection rates, protocol anomalies and known exploit signatures. IPS can be placed at strategic enforcement points where inline blocking is operationally appropriate. Detection should be correlated with NAC identity, DHCP leases, switch/AP telemetry and endpoint events.

Justification: IDS/IPS provides a second layer of defense. NAC controls who/what receives access, while IDS/IPS observes and can block malicious network behavior. This defense-in-depth approach is important because a device can be correctly authenticated and still be compromised.

8.3 Endpoint Remediation – Remove the Underlying Cause

- Preserve relevant volatile and persistent evidence before destructive remediation when incident severity warrants it.
- Run endpoint security scans and review process, persistence, browser, network and security logs.
- Patch the operating system and vulnerable applications; remove unauthorized scanning or remote-access tools.
- Rotate or reset credentials if compromise or credential exposure is suspected.
- Verify endpoint firewall, anti-malware/EDR, disk encryption and security-policy compliance.

Reassess NAC posture and restore the device to the normal VLAN only after successful validation.

9. Incident Response Plan

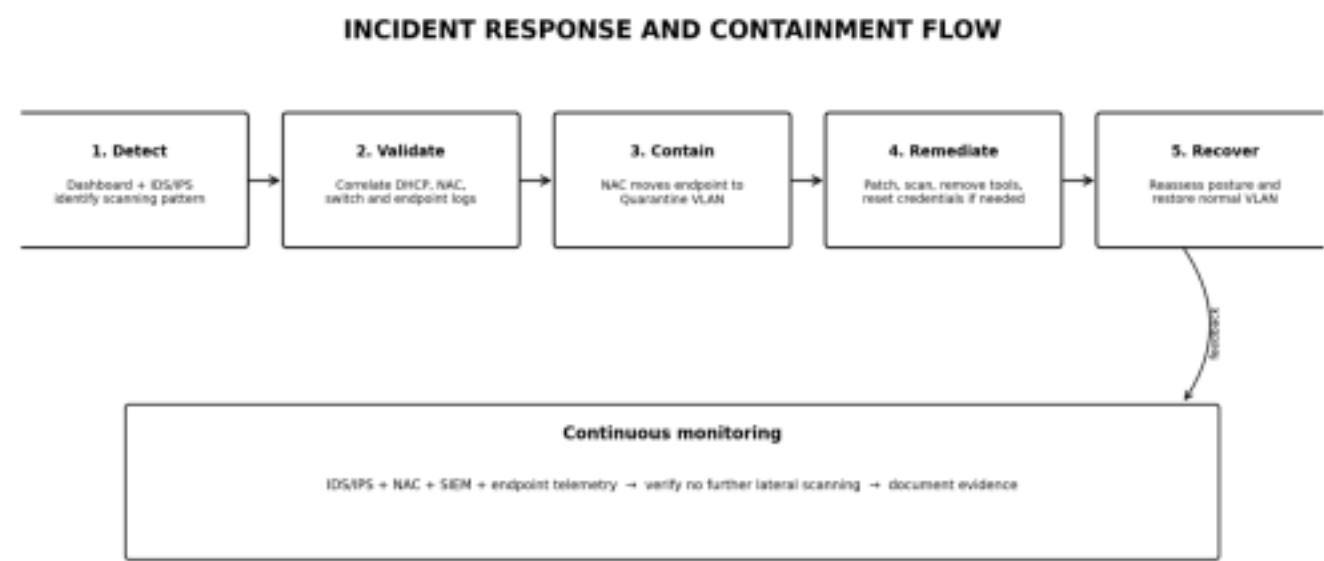


Figure 3. Incident response workflow from detection through recovery.

Phase	Immediate Actions	Evidence	Owner
Preparation	Maintain NAC, IDS/IPS, EDR, logging and documented isolation procedures.	Policies, baselines, asset inventory	SOC / Network Team
Detection & Analysis	Confirm source identity; correlate IP/MAC/user/AP/switch/end po int events.	NAC, DHCP, switch, IDS/IPS, EDR, firewall logs	SOC
Containment	Move source to Quarantine VLAN; block unnecessary east west traffic.	NAC change log, ACL/IPS events	Network + SOC
Eradication	Investigate malware/tools; patch and harden endpoint.	EDR findings, hashes, process/network evidence	Endpoint Team

Recovery	Re-test posture and restore normal authorization cautiously.	NAC posture result, clean scan	SOC + Endpoint
Lessons Learned	Review why traffic was reachable and improve detection/segmentation.	Incident timeline and control gaps	Security Lead

10. Risk Assessment

Risk is assessed qualitatively using Likelihood × Impact. The scenario should be treated as High priority because cross VLAN reconnaissance can precede lateral movement, but the final severity should be adjusted after confirming whether the activity was authorized.

Risk	Likelihood	Impact	Rating	Mitigation
Unauthorized internal reconnaissance	High	High	High	NAC quarantine + IDS/IPS + ACLs
Lateral movement to managed systems	Medium–High	High	High	Least-privilege inter VLAN policy
Credential compromise	Medium	High	High	EDR + MFA + credential reset if indicated

IoT/service exploitation	Medium	High	High	IoT isolation + allow-listing
False positive / authorized scan	Medium	Medium	Medium	Validate change records and scan authorization
Operational disruption from isolation	Medium	Medium	Medium	Controlled quarantine policy and recovery testing

11. Recommended Control Policy

- Student/BYOD devices should not receive unrestricted access to management or sensitive server networks. •

Inter-VLAN communication should be deny-by-default, with explicit exceptions for required services. • NAC should use device identity and posture to assign normal, restricted, guest or quarantine access. • IDS/IPS alerts for scanning should be correlated with the source identity and exposed to the SOC for rapid triage. • Endpoint health should be continuously assessed; authentication alone should not imply trust. • Management interfaces should be isolated and accessible only from approved administrative networks.

- Security logs should be time-synchronized and retained according to institutional incident-response requirements.

12. Investigation Checklist

- Confirm the endpoint's MAC address, IP lease, username/device identity and physical/wireless attachment point. • Determine whether the scanning activity was authorized by the institution or part of a security lab. • Review DHCP, DNS, switch/AP, firewall, IDS/IPS, NAC and EDR logs for the incident window. • Identify destination hosts and services contacted across each VLAN.
- Check for successful connections, authentication attempts, exploitation signatures or data transfer. • Quarantine the endpoint if malicious or unauthorized behavior remains plausible.
- Preserve evidence before reimaging or deleting suspicious files when forensic analysis is required. • Remediate, patch and validate the endpoint before restoring access.
- Review segmentation and firewall/ACL rules that allowed cross-VLAN reachability.
- Document the final root cause, evidence, impact and corrective actions.

13. Conclusion

The campus dashboard pattern represents a security-relevant event because a student endpoint is attempting to discover or contact multiple internal VLANs. The strongest response is layered rather than relying on a single control. NAC provides identity- and posture-based admission and can isolate the endpoint into a Quarantine VLAN. IDS/IPS supplies independent network visibility and active blocking where appropriate. Endpoint remediation addresses the possibility that the device itself is compromised or misconfigured. Together, these controls reduce lateral movement, limit blast radius, improve incident evidence and support safe recovery.

The investigation should not label the student device as malicious solely from a scan pattern. The final root cause must be supported by correlated evidence and by ruling out authorized security testing or legitimate software behavior.

14. References

- Cisco, Cloud Campus LAN Design Guide (CVD): campus VLAN segmentation, management, corporate, BYOD, guest and IoT network segments.
- Cisco, Campus Design guidance for 802.1X and NAC: access control, VLAN assignment and network compartmentalization.
- Cisco, Enterprise Campus / SAFE design guidance: campus NAC integration and network-based intrusion prevention.
- Arista, Campus Network and Security Design Guide: security zones, segmentation and lateral-movement risk. • Pearson IT Certification, Network+ study guide: IDS versus IPS placement and operational roles.